

AVops Webex Support Agents

AWS Architecture & Corporate AI Security Posture Plan

Phase 1 → Phase 3 Roadmap · Confidential — Internal Use Only

Prepared by AVops Engineering · March 09, 2026

Phase 1 Home-Lab / Dev	NOW	DynamoDB · S3 · SQS · Secrets Manager
Phase 2 Staging	NEXT	VPC · Cognito · WAF · KMS CMKs · CloudTrail
Phase 3 Corp AI Posture	TARGET	Zero-Trust · PII Scrub · SOC 2 · GDPR

Table of Contents

- 1. Current Architecture (Phase 1 — AWS Dev / Home-Lab)
- 2. Phase 2 — Staging (Pre-Production Hardening)
- 3. Phase 3 — Corporate AI Security Posture
- 4. Scaling Architecture (Phase 3 Target State)
- 5. Implementation Checklist
- 6. Cost Estimates (Monthly)
- 7. Open Items / Decisions Needed

1. Current Architecture (Phase 1 — AWS Dev / Home-Lab)

Status: Phase 1 deployed. This document is the roadmap from home-lab through full corporate AI security posture (Phase 3).

The AVops Webex Support system uses a 7-agent Claude AI pipeline to receive, triage, diagnose, and resolve AV support requests submitted via Webex. All state is persisted to AWS-managed services:

Webex Space ■ webhook POST ▼ FastAPI (port 8080) ■ ■■■■ DynamoDB (tickets, devices, agent-state) ■■■■ S3 (logs, reports, firmware) ■■■■ SQS FIFO (agent-tasks, webex-events) ■■■■ Anthropic API (7-agent pipeline) ■ claude-opus-4-6 (Orchestrator → Researcher → Planner → Implementer → Tester → Reviewer → Documenter)

1.1 Phase 1 AWS Services

Service	Purpose	Resource / Config
DynamoDB	Tickets, devices, rooms, agent state	4 tables, PAY_PER_REQUEST billing
S3	Logs archive, reports, firmware files	3 buckets, AES-256 SSE, versioned
SQS FIFO	Agent task dispatch + Webex event buffer	2 queues + dead-letter queues
Secrets Manager	Webex token, Anthropic key, SQS URLs	3 secrets
IAM	Least-privilege app role	1 role, no wildcard actions

1.2 Deployment Options

- Option A — Local / Home-Lab: Docker Compose + LocalStack

```
docker compose up -d # FastAPI + React + LocalStack on localhost
```

- Option B — EC2 / ECS Fargate (manual):

```
pip install -e ".[dev]" uvicorn avops.main:app --host 0.0.0.0 --port 8080
```

- Option C — CDK automated deploy (creates all AWS resources):

```
cd infrastructure/cdk pip install -r requirements.txt cdk deploy -c env=dev -c account=YOUR_ACCOUNT -c region=us-east-1
```

2. Phase 2 — Staging (Pre-Production Hardening)

2.1 Networking

- **VPC** with private subnets for all ECS tasks — no public IPs on app layer
- **NAT Gateway** for outbound-only internet (Webex webhooks, Anthropic API)
- **VPC Endpoints** for DynamoDB, S3, SQS, Secrets Manager — traffic never leaves AWS backbone
- **Security Groups**: ECS tasks accept traffic from ALB only; port 8080 only

Internet → ALB (public subnet, WAF) → ECS Fargate (private subnet) ■ VPC Endpoints → DynamoDB / S3 / SQS

2.2 Authentication & Authorization

- **Amazon Cognito User Pool** — dashboard login for AV engineers
- **API Gateway** in front of FastAPI with Cognito JWT authorizer
- RBAC roles: av-engineer (read-only) · av-admin (read-write) · av-ops (full)
- FastAPI: `ENABLE_AUTH=true` enables JWT validation on all protected routes

2.3 Encryption Upgrades

Resource	Phase 1	Phase 2 Upgrade
DynamoDB	AWS-managed key	CMK (Customer Managed Key) via KMS
S3	SSE-S3 (AES-256)	SSE-KMS with CMK
SQS	Default encryption	KMS CMK
Secrets Manager	Default	CMK + auto-rotation enabled

2.4 Logging & Monitoring

- **AWS CloudTrail** — all API calls logged to dedicated S3 bucket
- **CloudWatch Logs** — FastAPI structured logs → Log Groups per environment
- **CloudWatch Metrics** — tickets/min, agent pipeline latency, error rate
- **CloudWatch Alarms** — DLQ depth > 0, API 5xx rate > 1%, Anthropic 429s
- **AWS Config** — drift detection on DynamoDB policies, S3 bucket ACLs

2.5 Web Application Firewall (WAF)

- **AWS WAF** attached to Application Load Balancer:
 - AWS Managed Rules: Core Rule Set + Known Bad Inputs
 - Rate limiting: 100 requests per 5 min per source IP
 - Geo-blocking: restrict to corporate office CIDRs + Webex IP ranges
 - Custom rule: block requests to webhook endpoint with non-Webex User-Agent

3. Phase 3 — Corporate AI Security Posture

3.1 AI Model Governance

Requirement	Implementation
Model approval	Only Anthropic Claude models — no open-weight / self-hosted models
Data residency	All prompts & responses stay in AWS us-east-1
PII scrubbing	Strip emails & device passwords from Anthropic API payloads pre-send
Prompt injection	Input sanitisation layer before every agent dispatch
Output validation	JSON schema validation on all 7 agent outputs
Cost controls	max_budget_usd per ticket + CloudWatch billing alarm
Audit trail	Every API call logged: ticket_id, tokens used, model, latency

3.2 Zero-Trust Network Architecture

[illegible]

3.3 Data Classification

Data Type	Classification	Controls
Webex messages	Confidential	Encrypted at rest + transit · 365-day retention
Device credentials	Secret	Secrets Manager only · never logged · rotated 90 days
Agent transcripts	Internal	S3 SSE-KMS · 365-day lifecycle · presigned URLs only
Support tickets	Internal	DynamoDB CMK · Point-in-time recovery enabled
Firmware files	Public	S3 standard · no PII · public read restricted

3.4 IAM Hardening — Least Privilege Example

Replace broad table-level grants with fine-grained action-level permissions:

```
# Tickets table – only the 4 operations the app actually needs actions = [ "dynamodb:PutItem",  
"dynamodb:GetItem", "dynamodb:UpdateItem", "dynamodb:Query", ] # Explicitly denied: Scan,  
DeleteItem, DescribeTable, BatchWriteItem # Condition: aws:RequestedRegion == us-east-1 only
```

3.5 Secrets Rotation

Secret	Rotation Method	Frequency
Webex Bot Token	Secrets Manager auto-rotation via Lambda	Every 90 days
Anthropic API Key	Manual (no rotation API)	Every 90 days
Device Credentials	CyberArk / Vault integration (future)	Every 30 days

3.6 Compliance Framework Mapping

Framework	Controls Required
SOC 2 Type II	CloudTrail · AWS Config · VPC Flow Logs · WAF · PITR
NIST 800-53	CMK · MFA enforced · Least-privilege IAM · Full audit logging
Corp AI Policy	Model registry · PII stripping · Cost cap · Human override
GDPR (if EU data)	Data residency config · Right-to-erasure API · Consent logging

4. Scaling Architecture (Phase 3 Target State)

```

+ AWS us-east-1 + Webex Bot + ALB (WAF
+ Cognito authorizer) + Webhook + ECS Fargate (FastAPI) + Corp Users
+ Port 8080 (2 AZs) + (Cognito JWT) + ECS Fargate (SQS Worker) +
agent-tasks.fifo + Claude API + (7 agents) + DynamoDB S3 SQS Secrets Mgr +
CloudWatch CloudTrail Config WAF +

```

Auto-Scaling Triggers

Metric	Threshold	Action
SQS agent queue depth	> 50 messages	Scale ECS worker +2 tasks
FastAPI p99 latency	> 2 seconds	Scale FastAPI service +2 tasks
DynamoDB consumed RCU	> 80% provisioned	Enable DynamoDB auto-scaling
Anthropic API 429 rate	> 3 in 60 sec	Exponential backoff (built-in SDK)

5. Implementation Checklist

Phase 1 → Phase 2 (Staging)

■	Deploy CDK stack (infrastructure/cdk/avops_stack.py)
■	Populate Secrets Manager: Webex Bot Token + Anthropic API Key
■	Set USE_SECRETS_MANAGER=true in ECS task definition
■	Create Cognito User Pool + app client
■	Set ENABLE_AUTH=true + Cognito environment variables
■	Enable WAF on Application Load Balancer
■	Configure CloudWatch alarms (DLQ depth, 5xx rate)
■	Enable CloudTrail in all active regions
■	Verify Webex webhook signature validation in production
■	Load test: 100 concurrent tickets through 7-agent pipeline

Phase 2 → Phase 3 (Corp AI Posture)

■	Create KMS CMKs for DynamoDB, S3, SQS encryption
■	Enable Secrets Manager auto-rotation for Webex Bot Token
■	Implement PII scrubber layer before all Anthropic API calls
■	Add max_budget_usd cap per ticket to BaseAgent class
■	Deploy VPC with private subnets + VPC endpoints (no internet for data services)
■	Configure Cognito MFA (TOTP or SMS) for all engineer accounts
■	Run SOC 2 gap assessment with compliance team
■	Register claude-opus-4-6 in corporate AI model registry
■	Add PagerDuty escalation for priority=critical tickets
■	Conduct penetration test on webhook endpoint and API Gateway
■	Enable VPC Flow Logs → CloudWatch for network anomaly detection
■	GDPR review: confirm no EU employee data in scope, or configure residency

6. Cost Estimates (Monthly)

Note: Anthropic Claude costs dominate. Cost scales with ticket volume and number of agent turns per ticket (7 agents × avg. 2K tokens each).

Phase 1 — Dev / Home-Lab (~500 tickets / month)

AWS Service	Estimated Cost
DynamoDB (PAY_PER_REQUEST)	~\$2
S3 — logs + reports	~\$1
SQS	~\$0.01
Secrets Manager	~\$1.50
Anthropic Claude (7 agents × 500 tickets)	~\$35–85
Total	~\$40–90 / month

Phase 3 — Production (~5,000 tickets / month)

AWS Service	Estimated Cost
ECS Fargate (2 services, 2 AZs)	~\$80
DynamoDB	~\$20
S3	~\$5
SQS + DLQs	~\$1
Secrets Manager	~\$3
WAF	~\$10
CloudWatch + CloudTrail	~\$15
KMS (CMKs)	~\$6
Anthropic Claude	~\$350–850
Total	~\$490–990 / month

7. Open Items / Decisions Needed

The following items require team input before Phase 2 deployment can begin.

1. Webex Bot Scope

Should the bot respond in individual Webex DMs only, or also in shared group support spaces? Group spaces require additional moderation and PII handling rules.

2. AI Model Approval

Does the corporate AI policy require claude-opus-4-6 to be formally registered in the model registry before production use? If so, initiate the approval workflow.

3. Device Credential Vault

Should AV device passwords be stored in AWS Secrets Manager (already provisioned) or integrated with an enterprise vault (CyberArk / HashiCorp Vault)?

4. GDPR Applicability

Are any European employees or conference rooms in scope? If yes, data residency configuration (EU-only DynamoDB table, S3 bucket in eu-west-1) is required before go-live.

5. On-Call Integration

Should priority=critical tickets trigger a PagerDuty / OpsGenie escalation in addition to the automated agent response? Recommended for exec/boardroom incidents.

6. Anthropic Rate Limits

Confirm the current Anthropic account tier (tokens per minute) before production rollout. At 7 agents × 5,000 tickets/month, peak burst may require a rate limit increase.

This document is INTERNAL. Do not distribute outside the AV Engineering and IT Security teams without approval from AVops leadership.